

Downloadable for the Product Growth Team OS

Source: [github.com/aakashg/product-growth-team-os · team/compliance/sensitive-data-checklist.md](https://github.com/aakashg/product-growth-team-os/tree/master/team/compliance/sensitive-data-checklist.md)

Sensitive-Data Control Checklist

A standalone control framework for adopting the Team OS in regulated environments (SOC2 Type II, GDPR with EU data subjects, HIPAA-adjacent, GLBA, PCI). Map each row to the named artifact in your repo. If a row isn't satisfied, document why and set a remediation date.

Use case: hand this to your CISO / DPO / compliance lead during the adoption review. Every artifact referenced ships with the starter; the table is your mapping from "yes we have a policy" to "yes we have a control with a named owner and an audit artifact."

Layer 1: Classify (data minimization at the input layer)

Control	Artifact	Verification
Customer-side personal names stripped from internal summaries	<code>.claude/skills/customer-call-summary/SKILL.md</code> rules 1-2 (role-only attribution)	Spot-check 5 random summaries; CI Gitleaks scan in PR
GDPR Article 9 special categories explicitly excluded from both summary AND transcript files	<code>.claude/skills/customer-call-summary/SKILL.md</code> rule 6	Skill prompt enforces; quarterly random-sample review
Revenue figures, salary, exact ARR dollar amounts kept out of summaries	<code>customer-call-summary/SKILL.md</code> rule 4; <code>portfolio.yaml</code> uses ARR bands not exact values	Schema validates band values
Transcripts and summaries separated by folder so a query can synthesize across summaries without ever reading raw transcripts	<code>accounts/{customer}/calls/summaries/</code> vs <code>transcripts/</code>	Folder structure enforced by <code>/customer-call</code> command
Outgoing-email exception (first name in salutation only) is the single, narrow carve-out	<code>customer-call-summary/SKILL.md</code> rule 5	Email body is reviewed before send
Sub-processor disclosure — your team knows that LLM queries send file content to your AI vendor	<code>SECURITY.md</code> "Sub-processor disclosure" section	Documented in your customer DPA

Layer 2: Consent (named external use is opt-in)

Control	Artifact	Verification
Customer names in external assets (case studies, sales decks, blog posts) require an explicit signed permission record	<code>customers/case-studies/permissions.yaml</code>	Form on file; spot-check links from quotes back to permission rows
Permission records have explicit <code>approved_uses</code> allow-list and <code>do_not_use</code> deny-list	<code>permissions.yaml</code> schema	YAML lint; review at quarterly compliance
Permission expirations enforced; named quotes pulled when expired	<code>permissions.yaml#permission_expires</code> , annual re-confirmation	Calendar reminder + review
Spokesperson change (champion departure) re-triggers re-confirmation before continued use	<code>permissions.yaml#last_reconfirmed</code> and CSM workflow	CS team retros include this check
Non-permissioned customer voice stays in role-attributed internal summaries; never surfaces externally	Layered: classification at write time + permissions registry at publish time	Diff between <code>accounts/</code> (role-only) and <code>case-studies/</code> (named)

Layer 3: Enforce (controls that block the failure mode at write time, not just policy)

Control	Artifact	Verification
Branch protection on <code>main</code> — require PR review, no force push, no admin bypass	GitHub Settings → Branches; documented in <code>SECURITY.md</code>	Periodic review of branch protection rules
<code>CODEOWNERS</code> for sensitive folders (<code>customers/</code> , <code>analytics/data-catalog.yaml</code> , <code>case-studies/permissions.yaml</code>)	<code>.github/CODEOWNERS</code>	Commits to listed paths require named-owner review
Signed commits required if your industry needs non-repudiation	GitHub branch protection setting	Verify on at least one recent PR
Pre-commit hook scans for emails, common secret patterns, SSN/EIN/MRN regexes	<code>SECURITY.md</code> "Pre-commit Hook" sample; team-installed locally	Sample commit attempting to add an email is blocked
CI security scanner (Gitleaks or equivalent) blocks PRs containing PII or secrets	<code>.github/workflows/security-scan.yml</code> (template — wire up to your CI)	Failed PR can be reproduced in test
GDPR Article 17 erasure runbook documented (<code>git filter-repo</code> + force-push + sub-processor deletion ticket)	<code>SECURITY.md</code> "Right to erasure" section	Documented retention SLA; one practice run on a synthetic record
Retention schedule defined per artifact type (transcripts, summaries, decisions, win-loss, etc.)	<code>team/compliance/dpia-template.md</code> Section 5	Quarterly purge job or documented manual cadence
Access reviews on the GitHub repo membership at least quarterly	Documented in your access-management policy	Audit log of removals
DPIA completed and signed by DPO before regulated-data adoption	<code>team/compliance/dpia-template.md</code> filled in	Signed PDF on file

Layer 4: Sub-Processor / Vendor Posture (specific to AI-tool query exposure)

When your team queries this repo through Claude Code, Cursor, OpenAI Codex, or any LLM-backed tool, file contents pass to the LLM provider. This is sub-processor exposure under GDPR Article 28 and SOC2 sub-service-organization disclosure.

Control	Artifact	Verification
DPA signed with your LLM vendor (Anthropic, OpenAI, etc.)	Vendor contract	Counter-signed copy in legal repository
Zero-retention API endpoint enabled where available	Vendor configuration	Verified in vendor admin console
Data residency requirement (US vs. EU) addressed for EU data subjects	Vendor configuration	Documented
Sub-processor list in your customer DPAs updated to disclose the LLM vendor	Customer-facing DPA	Legal sign-off
Quarterly vendor security-posture review on file (SOC2 reports etc.)	Vendor compliance portal	Reports collected in your GRC system

What This Checklist Doesn't Cover

- **Network controls** — VPN, firewall, IDS — owned by your IT/security team, not the repo
- **Endpoint security** — laptop encryption, MDM — same
- **Identity and access for non-GitHub services** — Google Workspace, Slack, Linear/Jira/Asana — owned by your IT team
- **Backup and disaster recovery** — depends on your GitHub plan's backup posture and your separate DR strategy

The Team OS is the **markdown-and-YAML institutional-memory layer**. It does not replace your existing security stack. The controls above are what turn the repo from "shared Google Drive" into "a controlled artifact set you can audit."

Adoption Checklist (use during initial setup)

- ☐ Classification controls (Layer 1) — review with team lead
- ☐ Consent registry initialized (Layer 2) — `permissions.yaml` exists with at least the schema in place
- ☐ Branch protection enabled on `main`
- ☐ CODEOWNERS file in place for sensitive folders
- ☐ Pre-commit hook installed locally for at least the maintainer
- ☐ CI security scanner wired up
- ☐ GDPR Art. 17 runbook reviewed by DPO

- ☐ Retention schedule defined and added to your GRC tracker
 - ☐ LLM vendor DPA on file
 - ☐ Zero-retention endpoint configured (where available)
 - ☐ DPIA signed (regulated industries only)
 - ☐ First quarterly access review scheduled
-

When This Checklist Is Wrong For You

- **Pre-revenue startup with no enterprise customers:** most of Layer 4 is overkill. Run Layers 1-2 and the basics of Layer 3 (branch protection, pre-commit hook). Defer the rest until your first enterprise contract requires it.
 - **Healthcare with PHI:** this checklist is *not sufficient* for HIPAA Security Rule. PHI should not be in the repo at all. Use the Team OS as the *summary* layer; PHI lives in your HIPAA-compliant systems.
 - **Single-tenant on-prem deployment:** most LLM-vendor concerns drop. Run Layers 1-3 against your local model serving setup.
 - **Government / FedRAMP:** this checklist is a starting point only. Your control catalog is much larger; map this checklist's controls into NIST 800-53 / FedRAMP rev. 5 control families.
-

Related

- [SECURITY.md](#) — full sample hooks, branch protection settings, erasure runbook
- [compliance/dpia-template.md](#) — DPIA template ready for DPO review
- [.claude/skills/customer-call-summary/SKILL.md](#) — PII rules in the place they're enforced
- [customers/case-studies/permissions.yaml](#) — consent registry schema
- [team/adoption-playbook.md](#) Section 6 ("Sensitive Data") — three-layer model in the team-facing playbook